



Unidad Didáctica

**Delitos informáticos y tendencias en
auditoría de TI, Unidad V**

Contenido

Índice de Contenido	2
Introducción	3
Desarrollo de Contenidos	6
Conceptos generales en materia de ley: delitos, evidencias. peritaje, tipos de investigación, prueba pericia.....	6
Protección de la información y delitos informáticos.....	15
Auditoría Informática Forense.....	27
Bibliografía y Webgrafía	28
Glosario	28

En la era de la transformación digital, la información se ha consolidado como el activo más valioso de las organizaciones y, al mismo tiempo, como el blanco predilecto de una ciberdelincuencia cada vez más sofisticada. Los delitos informáticos ya no son una posibilidad remota; representan una realidad cotidiana que amenaza la confidencialidad, integridad y disponibilidad de los datos, erosionando la confianza de ciudadanos, empresas y gobiernos. Frente a este panorama, los profesionales de la auditoría de tecnologías de la información se ven llamados a trascender su rol tradicional de evaluadores de controles para convertirse en actores clave en la prevención, detección y persecución de estas conductas ilícitas.

La presente unidad didáctica, titulada “Delitos informáticos y tendencias en auditoría de TI”, aborda de manera sistemática los fundamentos jurídicos, los deberes de protección de la información y las metodologías forenses que todo auditor debe dominar para responder con eficacia a este desafío. El recorrido se ha organizado en tres ejes temáticos profundamente interconectados.

El primer eje desbroza los **conceptos generales en materia de ley**, comenzando por la tipificación de los delitos informáticos, tal como han sido recogidos por la legislación nicaragüense en la Ley N°. 1042, Ley Especial de Ciberdelitos, y por instrumentos internacionales como el Convenio de Budapest. Se estudiará la naturaleza de la evidencia digital, sus principios de manejo y la trascendental figura de la cadena de custodia, que constituye la columna vertebral para que un hallazgo técnico se convierta en prueba judicial. Se examinará, asimismo, el peritaje informático, los diversos tipos de investigación —criminal, corporativa y defensiva— y los requisitos que otorgan admisibilidad y valor probatorio a un dictamen pericial. Este primer acercamiento dota al auditor del lenguaje jurídico imprescindible para

comprender que su trabajo no opera en un vacío técnico, sino dentro de un ordenamiento que exige rigor procesal.

El segundo eje se adentra en la **protección de la información y su estrecha relación con los delitos informáticos**. Aquí se analizan los pilares de la seguridad —confidencialidad, integridad y disponibilidad— a la luz de la Ley N°. 787, Ley de Protección de Datos Personales, que en Nicaragua impone a las entidades el deber de salvaguardar los datos personales bajo los principios de transparencia, seguridad y responsabilidad proactiva. Se identifican las principales figuras delictivas que atentan contra esos pilares, desde el acceso ilícito y el phishing hasta el ransomware y el sabotaje informático, contextualizadas con datos que reflejan la incidencia de estas amenazas en la región. Se revisan, además, las medidas técnicas y organizativas que constituyen el estándar de diligencia exigible —con referentes como la norma ISO/IEC 27001— y el rol del auditor de TI como evaluador del cumplimiento normativo y como asesor estratégico en la construcción de resiliencia organizacional.

El tercer eje se concentra en la **auditoría informática forense**, la disciplina que fusiona la auditoría de sistemas con la metodología de investigación criminal. Se despliega su marco normativo de referencia en Nicaragua —que incluye el Código Procesal Penal y el Manual de Tratamiento de la Evidencia y Cadena de Custodia del Poder Judicial—, así como los estándares internacionales que orientan la recolección y análisis de evidencia digital. Se detallan las fases metodológicas del proceso forense, desde la identificación y autorización hasta la documentación y presentación del dictamen pericial, con especial énfasis en la cadena de custodia como garantía de integridad. Se exploran las herramientas y técnicas de uso común, el perfil del perito informático forense, la estructura del informe pericial y los desafíos que plantean tendencias como el cifrado masivo, la computación en la nube y la explosión de los dispositivos móviles.

En conjunto, los contenidos de esta unidad no solo ofrecen una actualización conceptual, sino que aspiran a desarrollar en el estudiante y en el profesional de auditoría una mirada integral: la que entiende que en el entorno digital actual, cada control que se evalúa protege un bien jurídico, cada vulnerabilidad no mitigada puede ser la puerta de entrada de un delito, y cada hallazgo de auditoría puede convertirse, con el tratamiento forense adecuado, en una prueba determinante ante un tribunal. Bienvenidos a este recorrido por la intersección entre el derecho, la tecnología y la auditoría, un espacio donde la rigurosidad técnica y el compromiso ético son las mejores herramientas para enfrentar la ciberdelincuencia.

Conceptos generales en materia de ley: delitos, evidencias.

peritaje, tipos de investigación, prueba pericia

El objetivo de este apartado es profundizar en los conceptos jurídicos y técnicos que sustentan la investigación de los delitos informáticos. Se abordarán las definiciones clave, se contextualizarán con la normativa nicaragüense, y se explicará el proceso que transforma un simple dato electrónico en una prueba con validez judicial.

Delitos informáticos: concepto, clasificación y marco legal nicaragüense

Definición y naturaleza jurídica: Los delitos informáticos, también conocidos como ciberdelitos, son aquellas conductas ilícitas que utilizan las Tecnologías de la Información y la Comunicación (TIC) como medio o como fin para atentar contra bienes jurídicos protegidos, como la confidencialidad, integridad y disponibilidad de los datos y sistemas informáticos. La doctrina distingue entre dos categorías:

- **Delitos informáticos puros o propios:** Aquellos en los que el bien jurídico tutelado es directamente la información, los datos o los sistemas informáticos. Un ejemplo típico es el acceso ilícito a un sistema.
- **Delitos informáticos impropios o mixtos:** Son aquellos delitos tradicionales (como la estafa, el acoso o la difamación) que, por su nueva modalidad de comisión, se sirven de los medios informáticos como herramienta o instrumento.

Clasificación común de los ciberdelitos:

A nivel internacional, el principal referente para la clasificación de estos delitos es el **Convenio sobre la Ciberdelincuencia**, conocido como Convenio de Budapest (2001). Este tratado, el primero en abordar los crímenes en Internet, tipifica las siguientes categorías de delitos para armonizar las legislaciones nacionales y facilitar la cooperación internacional:

1. **Delitos contra la confidencialidad, integridad y disponibilidad de datos y sistemas informáticos:** Incluye conductas como el acceso ilícito, la interceptación ilícita, la interferencia en datos y sistemas, y el abuso de dispositivos.
2. **Delitos informáticos en sentido estricto:** Comprende la falsedad informática y el fraude informático.
3. **Delitos relacionados con el contenido:** Abarca la producción, difusión y posesión de pornografía infantil.
4. **Delitos relacionados con la propiedad intelectual:** Se refiere a la infracción de los derechos de autor y derechos conexos a través de medios digitales.

Marco legal en Nicaragua:

En Nicaragua, la respuesta jurídica frente a la ciberdelincuencia se materializa principalmente en la **Ley N°. 1042, "Ley Especial de Ciberdelitos"**, aprobada el 27 de octubre de 2020 y publicada en La Gaceta, Diario Oficial N°. 201 del 30 de octubre de 2020.

- **Objeto de la Ley:** Su finalidad es la "prevención, investigación, persecución y sanción de los delitos cometidos por medio de las Tecnologías de la Información y la Comunicación (TIC), en perjuicio de personas naturales o jurídicas".
- **Ámbito de aplicación:** La ley es de orden público y se aplica a toda persona, nacional o extranjera, que cometa los delitos previstos en ella, ya

sea dentro del territorio nicaragüense o en el extranjero, siempre que los efectos del delito se produzcan en el país.

- **Tipificación de conductas:** La Ley 1042 tipifica una serie de conductas delictivas que se alinean con las categorías del Convenio de Budapest. Entre los principales delitos que contempla se encuentran:
 - **Acceso ilícito a sistemas informáticos:** Penetra en un sistema sin autorización.
 - **Interceptación ilícita de datos informáticos:** Capta, graba o desvía comunicaciones y datos.
 - **Interferencia en datos y sistemas:** Provoca daños, borrado, deterioro, alteración o supresión de datos informáticos.
 - **Fraude informático:** Obtiene un beneficio económico ilícito mediante la manipulación de datos o sistemas.
 - **Falsedad informática:** Crea o utiliza documentos o firmas electrónicas falsas.
 - **Delitos contra la integridad de sistemas informáticos del Estado:** Protege de manera especial los sistemas destinados a la prestación de servicios públicos.
- **Reformas y evolución:** En septiembre de 2024, la Asamblea Nacional de Nicaragua aprobó las Leyes N°. 1218 y N°. 1219, que reforman y adicionan artículos a la Ley N°. 1042. Estas reformas, según sus promotores, buscan fortalecer la prevención y sanción de delitos cometidos a través de redes sociales y aplicaciones móviles, incluyendo la difusión de información que pueda causar “alarma, desorden o temor público” o que afecte la reputación de las personas. Una reforma clave fue la inclusión del Artículo 11 bis, que establece la “Responsabilidad Penal de las Personas Jurídicas” en delitos relacionados con la integridad de los sistemas informáticos.

Es fundamental que el auditor informático conozca este marco legal, ya que su trabajo puede revelar indicios de conductas que encuadran en estos tipos penales, lo que activaría las obligaciones de denuncia y los protocolos de preservación de evidencia que veremos a continuación.

Evidencias digitales: concepto, principios y cadena de custodia

Definición y características: La evidencia digital es cualquier información almacenada o transmitida en formato binario que puede ser utilizada en un proceso judicial o investigación. A diferencia de la evidencia física, posee tres características inherentes que la hacen particularmente compleja:

1. **Volátil:** Puede perderse o alterarse con facilidad por el simple paso del tiempo, el apagado de un sistema o la ejecución de procesos normales.
2. **Intangible:** No tiene una representación física directa; lo que se observa es el resultado de la interpretación del código binario.
3. **Frágil y fácilmente alterable:** Un simple acceso no controlado a un archivo puede modificar sus metadatos (fecha de último acceso), comprometiendo su integridad y, por ende, su valor probatorio. De aquí surge la necesidad de protocolos estrictos para su manejo.

Principios de manejo y la cadena de custodia: Para que una evidencia digital sea admisible en un proceso judicial, su manejo debe regirse por principios que garanticen su autenticidad e integridad. Estos principios se materializan en la **Cadena de Custodia**, un concepto central en el proceso penal nicaragüense.

- **Base legal en Nicaragua:** El **Código Procesal Penal de la República de Nicaragua, Ley N°. 406**, establece las reglas generales para la obtención, custodia y valoración de la prueba. Si bien la ley procesal no es siempre tan específica como la técnica, el **"Manual de Tratamiento de la Evidencia y Cadena de Custodia"**, avalado por el Poder Judicial de Nicaragua, es una

herramienta que estandariza estos procedimientos, incluyendo la inspección ocular y el manejo de los elementos materiales de prueba.

- **Diferencia entre evidencia y prueba:** Este es un matiz crucial. La **evidencia** es el elemento en su estado bruto, el dato potencialmente relevante. La **prueba**, en cambio, es la evidencia que ya ha sido recolectada, preservada, analizada y exhibida ante el juez cumpliendo con todos los requisitos legales, y ha sido admitida como tal en el proceso. El perito informático es el profesional que guía este proceso de transformación. El manejo incorrecto de la evidencia la convierte en prueba inútil o impugnabile.

Peritaje informático: función del perito en el contexto legal nicaragüense

Definición y función: El peritaje informático es el conjunto de procedimientos técnicos y científicos destinados a identificar, recolectar, preservar, analizar y presentar la evidencia digital, a fin de que sea valorada como prueba fidedigna por un tribunal. El **perito informático** es el profesional especializado encargado de ejecutar este proceso y de traducir un lenguaje técnico complejo a uno que sea comprensible para jueces, fiscales y abogados.

Tipos de perito y marco normativo en Nicaragua: En el sistema procesal penal nicaragüense, regulado por la Ley N°. 406, la figura del perito está contemplada como un auxiliar de la administración de justicia cuyo dictamen es un medio de prueba. Se pueden distinguir dos tipos de peritos:

- **Perito judicial (o de oficio):** Es designado por el juez o el ministerio público. Generalmente, proviene de instituciones como el Instituto de Medicina Legal o la Policía Nacional. Por ejemplo, la Policía Nacional de Nicaragua realiza “Cursos de Acreditación de Peritos” en diversas especialidades para integrar a sus miembros en estas funciones de auxilio judicial.

- **Perito de parte:** Es propuesto por cualquiera de las partes involucradas en el litigio (el acusador o el acusado).

Requisitos habilitantes del perito: Para que el dictamen de un perito tenga la solvencia necesaria, el profesional debe cumplir con ciertos requisitos, que aunque no están codificados en un único instrumento, se derivan de la práctica forense y los estándares internacionales:

- Poseer una titulación oficial que acredite conocimientos especializados en el área informática o afín.
- Estar en pleno goce de sus derechos civiles y políticos, y carecer de antecedentes penales.
- Demostrar competencia técnica continua, ya sea a través de certificaciones, cursos de especialización o experiencia práctica comprobable.
- En el caso de peritos de instituciones públicas, como la Policía Nacional, deben superar un riguroso proceso de acreditación que incluye cientos de horas de formación teórica y práctica, como el curso de 648 horas que las autoridades han impartido a sus efectivos.

La Ley N°. 1042 refuerza la necesidad de la investigación técnica, exigiendo la colaboración de expertos para el rastreo y aseguramiento de las pruebas en entornos digitales.

Tipos de investigación

La naturaleza de los hechos y el interés que se persigue delimitan el tipo de investigación que se llevará a cabo. En el ámbito de la auditoría y la ciberdelincuencia, se distinguen principalmente tres tipos:

- **Investigación criminal (o pública):** Es la investigación oficial, dirigida por el Ministerio Público (Fiscalía) con el auxilio de la Policía Nacional y sus laboratorios forenses. Su objetivo es esclarecer la comisión de un delito tipificado en la Ley N°. 1042 u otras leyes penales, identificar al o los responsables y recolectar las pruebas necesarias para fundamentar una acusación penal. Se rige estrictamente por los principios de legalidad, objetividad y respeto a las garantías del debido proceso establecidos en el Código Procesal Penal. Nicaragua también ha adoptado instrumentos de cooperación internacional, como el **Convenio Iberoamericano de Cooperación sobre Investigación, Aseguramiento y Obtención de Pruebas en Materia de Ciberdelincuencia**, que facilita la investigación de delitos que trascienden las fronteras nacionales.
- **Investigación corporativa (o privada):** Es aquella que se origina en el seno de una empresa u organización, ante la sospecha de incidentes de seguridad, fraudes internos, fugas de información confidencial, mal uso de recursos informáticos o violaciones a las políticas internas de seguridad. Generalmente es realizada por equipos de auditoría interna o consultores externos especializados. Su propósito principal es determinar qué ocurrió, cómo ocurrió, el alcance del daño y, en su caso, recabar las evidencias necesarias para adoptar medidas disciplinarias internas, acciones civiles para el resarcimiento de daños, o presentar la denuncia formal ante el Ministerio Público para que se inicie una investigación criminal.
- **Investigación defensiva:** Es una modalidad de investigación privada llevada a cabo por la defensa técnica de una persona acusada (imputado). Su finalidad es recabar evidencia digital que pueda controvertir, desvirtuar o

poner en duda la prueba presentada por la fiscalía. Puede enfocarse en demostrar la alteración de la evidencia, la falta de integridad en la cadena de custodia, o la existencia de otras hipótesis plausibles que generen duda razonable en el juzgador.

Prueba pericial: valoración judicial y admisibilidad

Definición y valoración: La **prueba pericial** es el dictamen escrito u oral que emite el perito informático, en el cual plasma de manera objetiva y razonada sus hallazgos, análisis y conclusiones sobre la evidencia digital examinada. Se convierte así en el vehículo técnico por el cual la evidencia ingresa al debate judicial. A diferencia de un simple informe técnico, la prueba pericial sigue un método científico y se sujeta al escrutinio de las partes en un juicio.

Requisitos de admisibilidad del dictamen pericial: Para que una prueba pericial informática sea admitida y valorada positivamente por el juez, el dictamen debe cumplir con una serie de requisitos formales y técnicos, cuya omisión puede llevar a su inadmisión o a su falta de credibilidad:

1. **Pertinencia y utilidad:** El objeto de la pericia debe estar claramente definido y ser relevante para el caso concreto.
2. **Legitimidad de la evidencia:** El dictamen debe certificar que el material analizado (la evidencia) fue obtenido de forma lícita, sin violar derechos fundamentales. Esto enlaza directamente con la cadena de custodia.
3. **Integridad comprobada de la evidencia:** Es requisito indispensable que el perito adjunte el valor **Hash (como MD5, SHA-1 o SHA-256)** obtenido de la imagen o copia forense inalterable sobre la que trabajó (la copia bit a bit de la evidencia original). Este valor actúa como una "huella digital" única del archivo o disco, que permite demostrar que la evidencia analizada no ha sido modificada en lo más mínimo desde su recolección hasta su presentación en corte.

4. **Metodología sólida:** El perito debe explicar de manera clara el procedimiento y las herramientas forenses que utilizó, demostrando que su método es aceptado por la comunidad científica. Esto incluye el uso de bloqueadores de escritura y jaulas de Faraday para proteger la evidencia durante la adquisición.
5. **Documentación exhaustiva de la cadena de custodia forense:** El dictamen debe incluir el registro cronológico de todas las personas que manipularon la evidencia, en qué momento y con qué propósito, desde la incautación hasta la presentación en juicio. Debe demostrar que la evidencia ha permanecido íntegra y segura en todo momento.
6. **Informe claro y comprensible:** La estructura del informe debe ser lógica y presentar los hallazgos técnicos de forma que un juez, que no es un experto en informática, pueda comprender la relevancia de los hechos para formar su convicción. Debe incluir, como mínimo, antecedentes, cuestionario, metodología, herramientas, hallazgos y conclusiones periciales.

El cumplimiento riguroso de estos requisitos transforma un hallazgo digital en una **prueba pericial** sólida, capaz de sustentar una sentencia judicial. Para el auditor informático, comprender este flujo de trabajo es esencial, ya que los hallazgos de una auditoría interna podrían eventualmente convertirse en evidencia para un proceso legal.

Protección de la información y delitos informáticos

La información es el activo más valioso de cualquier organización en la era digital. Sin embargo, su naturaleza intangible y su exposición a un entorno tecnológico hostil la convierten en el blanco principal de la ciberdelincuencia. Este apartado explora los fundamentos, el marco legal nicaragüense y la relación entre la protección de la información y los delitos que atentan contra ella, cerrando con el rol del auditor de TI en este ecosistema.

Fundamentos de la protección de la información

Proteger la información no es solo una cuestión técnica, sino un imperativo estratégico y legal. Su base conceptual se sostiene sobre una tríada de principios conocida como CIA, por sus siglas en inglés, complementada por otros pilares fundamentales:

- **Confidencialidad:** Es la garantía de que la información solo es accesible para las personas, entidades o procesos autorizados. Una violación de este principio ocurre, por ejemplo, cuando un empleado accede sin permiso a la base de datos de recursos humanos o cuando un atacante externo roba secretos comerciales mediante un ataque de *phishing*. La confidencialidad se protege mediante controles como el cifrado de datos, la gestión de accesos lógicos y los acuerdos de confidencialidad con los empleados.
- **Integridad:** Este principio asegura que la información se mantenga exacta, completa y sin alteraciones no autorizadas durante todo su ciclo de vida. La modificación maliciosa de un registro contable, la alteración de una historia clínica o la inserción de datos falsos en un sistema de votación electrónica constituyen atentados contra la integridad. Para preservarla, se utilizan mecanismos como las firmas digitales, las funciones *hash*, los controles de versiones y la segregación de funciones, de modo que ninguna persona pueda modificar datos críticos sin dejar rastro y sin la debida autorización.

- **Disponibilidad:** Es la capacidad de que la información y los sistemas estén accesibles y operativos cuando los usuarios autorizados los necesitan. Un ataque de denegación de servicio distribuido (DDoS) que satura el sitio web de una tienda en línea, o un ataque de *ransomware* que cifra los archivos de una alcaldía y paraliza sus servicios, son ejemplos clásicos de violación a la disponibilidad. Las copias de seguridad, los sistemas redundantes y los planes de continuidad del negocio son salvaguardas esenciales para este pilar.
- **Principios complementarios:** Más allá de la tríada CIA, la protección de la información moderna se extiende a otros conceptos. La **autenticidad** busca verificar que la información proviene de la fuente que dice provenir, mientras que el **no repudio** impide que el emisor de un mensaje o el autor de una transacción niegue haberla realizado, función que cumplen las firmas electrónicas avanzadas. Finalmente, la **trazabilidad** permite reconstruir el historial de acciones sobre los datos, identificando quién hizo qué y cuándo. Estos principios en conjunto constituyen la base sobre la cual se diseñan las políticas de seguridad y se evalúa el impacto de los ciberdelitos.

Marco normativo de protección de datos y seguridad informática en Nicaragua

Nicaragua cuenta con un marco jurídico específico que establece las reglas para la protección de la información y la sanción de los delitos que la vulneran. Este marco se complementa con estándares internacionales y normas sectoriales que elevan el nivel de exigencia para las organizaciones.

La Ley N°. 787, Ley de Protección de Datos Personales (2012)

El principal instrumento normativo para la tutela de la información personal es la **Ley N°. 787**, aprobada el 21 de marzo de 2012 y publicada en La Gaceta, Diario Oficial N°. 61 del 29 de marzo de 2012. Esta ley tiene por objeto “la protección de la persona natural o jurídica frente al tratamiento, automatizado o no, de sus datos personales en ficheros de datos públicos y privados, a efecto de garantizar el derecho a la privacidad personal y familiar y el derecho a la autodeterminación informativa”. La autodeterminación informativa, definida en la propia ley, es “el derecho que tiene toda persona a saber quién, cuándo, con qué fines y en qué circunstancias toman contacto con sus datos personales”.

Los pilares de la Ley 787 son los siguientes:

- **Principios rectores del tratamiento de datos:** La ley introduce principios fundamentales como la transparencia, la seguridad y la confidencialidad en el manejo de los datos personales. Estos principios obligan a las entidades que procesan datos —denominadas “responsables del tratamiento”— a implementar medidas técnicas y organizativas adecuadas para proteger la información contra el acceso no autorizado, la pérdida, la alteración o cualquier otro tratamiento ilícito.
- **Derechos de los titulares de los datos:** La ley consagra los derechos de acceso, rectificación, cancelación y oposición, conocidos comúnmente como derechos ARCO. El titular de los datos puede solicitar al responsable del fichero que le informe qué datos suyos se están tratando y con qué finalidad (acceso); que corrija los datos inexactos o incompletos (rectificación); que los suprima cuando el tratamiento sea ilícito o ya no sea necesario para la finalidad original (cancelación); y que cese el tratamiento de sus datos en determinadas circunstancias (oposición). Adicionalmente, la ley exige que el consentimiento del titular sea previo, expreso, libre, inequívoco, específico e

informado, manifestación de voluntad sin la cual el tratamiento de datos deviene ilegítimo.

- **Régimen sancionador:** La Ley 787 establece sanciones para las empresas y organizaciones que incumplan con sus disposiciones. La Dirección de Protección de Datos Personales es la autoridad encargada de aplicar estas sanciones, que pueden incluir apercibimiento, multas económicas e incluso la suspensión de las operaciones relacionadas con el tratamiento de los datos personales. Este régimen refuerza la responsabilidad corporativa y la necesidad de que las organizaciones adopten una postura proactiva en la protección de los datos.

La Ley N°. 1042, Ley Especial de Ciberdelitos (2020)

Si la Ley 787 establece el deber de proteger los datos, la **Ley N°. 1042, Ley Especial de Ciberdelitos**, aprobada el 27 de octubre de 2020 y publicada en La Gaceta N°. 201 del 30 de octubre de 2020, tipifica las conductas delictivas que atentan contra esa protección en el entorno digital. Su objeto es “la prevención, investigación, persecución y sanción de los delitos cometidos por medio de las Tecnologías de la Información y la Comunicación, en perjuicio de personas naturales o jurídicas, así como la protección integral de los sistemas que utilicen dichas tecnologías, su contenido y cualquiera de sus componentes”. Esta ley es de orden público y se aplica a quienes cometan los delitos previstos en ella, dentro o fuera del territorio nacional.

Otras normas sectoriales

Además de las leyes generales, ciertos sectores regulados en Nicaragua imponen deberes específicos de seguridad informática que refuerzan la protección de la información. La **Superintendencia de Bancos y de Otras Instituciones Financieras** ha emitido normas como la de “Gestión de Riesgo Tecnológico”, cuyo objeto es “establecer los criterios mínimos de evaluación sobre la administración de los riesgos, la seguridad, la integridad, confidencialidad y disponibilidad de la información” en el sector financiero. Estas disposiciones obligan a los bancos y otras entidades supervisadas a implementar controles rigurosos que protejan los datos financieros de sus clientes, bajo amenaza de sanciones administrativas.

En conjunto, este entramado normativo crea un ecosistema legal en el que la protección de la información no es optativa, sino un deber jurídico cuyo incumplimiento puede acarrear consecuencias tanto administrativas como penales.

Principales delitos informáticos que vulneran la protección de la información

La tipificación penal en la Ley N°. 1042 permite agrupar los delitos informáticos según el pilar de la seguridad de la información que vulneran, evidenciando así la conexión directa entre la norma y los principios de protección:

- **Delitos contra la confidencialidad:** Atentan contra el secreto y la privacidad de los datos. La Ley 1042 tipifica:
 - *Acceso ilícito a sistemas informáticos:* Penetra en un sistema o se mantiene en él sin autorización, vulnerando los controles de acceso lógico.
 - *Interceptación ilícita de datos informáticos:* Capta, graba o desvía comunicaciones privadas de datos sin el consentimiento de los participantes, violando la confidencialidad de las transmisiones.

- *Espionaje informático*: Obtención no autorizada de secretos comerciales, información gubernamental o datos estratégicos almacenados en sistemas informáticos.
- **Delitos contra la integridad de los datos y sistemas**: Buscan alterar, dañar o suprimir información. Entre ellos se incluyen:
 - *Daño informático*: Destrucción, inutilización, alteración o supresión de datos informáticos, programas o sistemas ajenos sin autorización.
 - *Falsedad informática*: Creación, modificación o uso de documentos o firmas electrónicas falsas con la intención de inducir a error, afectando la autenticidad e integridad de la información.
- **Delitos contra la disponibilidad**: Impiden el acceso legítimo a los sistemas y datos. Se materializan en:
 - *Sabotaje informático*: Interferencia o alteración intencionada del funcionamiento de un sistema informático o los datos en él contenidos, con el propósito de causar perjuicio. Esto incluye los ataques de denegación de servicio (DoS/DDoS) y el ransomware.
 - *Extorsión cibernética*: Amenaza de dañar, cifrar o divulgar información sensible a menos que se pague un rescate, una modalidad creciente de ataque que combina la violación de la confidencialidad y la disponibilidad.
- **Delitos conexos**: Existen otras figuras estrechamente vinculadas que, aunque no encajen exclusivamente en una sola categoría, afectan la protección de la información. El *phishing*, como método para obtener credenciales de acceso mediante engaño, es la puerta de entrada a delitos de acceso ilícito y fraude informático. El *robo de identidad*, la ingeniería social y la utilización no autorizada de bases de datos completan el panorama de amenazas que explotan vulnerabilidades humanas y técnicas.

Las cifras en Nicaragua son elocuentes. Según datos presentados en el foro Tech Week Nicaragua 2025 por la firma global de ciberseguridad Kaspersky, en el país se registraron más de 90,000 intentos de ataque de fuerza bruta contra servicios de escritorio remoto (RDP) entre enero y julio de un mismo año. A nivel regional, la compañía reportó un promedio de 3,900 ataques de phishing diarios, tres ataques de ransomware y dos con troyanos bancarios por día, además de 18,000 ataques a dispositivos móviles en un solo año. Adicionalmente, los expertos advierten sobre la creciente complejidad del ransomware, que ahora emplea tácticas de “doble extorsión”, donde los criminales no solo cifran los datos sino que amenazan con reportar a la empresa víctima ante organismos normativos para impedir su certificación de seguridad. Estos datos subrayan la urgencia de una protección robusta.

Medidas de protección y responsabilidad organizacional

La mejor defensa contra los ciberdelitos es una estrategia de protección integral, que combine el cumplimiento normativo con la adopción de estándares internacionales y la implementación de controles técnicos y organizativos.

Principio de responsabilidad proactiva (accountability)

El marco normativo nicaragüense, en consonancia con las tendencias globales, impone a las organizaciones un deber de diligencia y responsabilidad activa en la protección de los datos. Ya no basta con reaccionar ante un incidente; se espera que las empresas demuestren que han adoptado medidas preventivas, proporcionales al riesgo, para salvaguardar la información que tratan. Esta responsabilidad proactiva, conocida como *accountability*, implica poder evidenciar ante la autoridad de control que se han implementado políticas, procedimientos y controles efectivos. Su incumplimiento no solo acarrea sanciones administrativas bajo la Ley 787, sino que puede generar responsabilidad penal por omisión si la

negligencia en la protección facilitó la comisión de un ciberdelito tipificado en la Ley 1042.

Alineación con estándares internacionales: ISO 27001 y NIST CSF

Para cumplir con este deber de diligencia, las organizaciones nicaragüenses recurren cada vez más a estándares internacionales que proporcionan un marco estructurado para la gestión de la seguridad de la información:

- **ISO/IEC 27001:** Es el estándar internacional más reconocido para el establecimiento, implementación, mantenimiento y mejora continua de un Sistema de Gestión de Seguridad de la Información (SGSI). La norma se basa en la tríada de confidencialidad, integridad y disponibilidad, y exige a las organizaciones identificar sus activos de información, evaluar los riesgos a los que están expuestos y seleccionar controles apropiados para mitigarlos (los cuales se detallan en el Anexo A de la norma). La certificación ISO 27001, otorgada por una entidad acreditada tras rigurosas auditorías, constituye una evidencia sólida del compromiso organizacional con la seguridad y es cada vez más valorada en relaciones comerciales y procesos de contratación pública. Su proceso de certificación, que incluye auditorías de vigilancia anuales y una recertificación cada tres años, garantiza la mejora continua del sistema de gestión.
- **Marco de Ciberseguridad del NIST (NIST CSF 2.0):** Desarrollado por el Instituto Nacional de Estándares y Tecnología de los Estados Unidos, el NIST CSF es un conjunto de directrices flexibles y basadas en riesgos que ayuda a las organizaciones a gestionar y reducir sus riesgos de ciberseguridad. Se organiza en funciones clave: Gobernar, Identificar, Proteger, Detectar, Responder y Recuperar. Aunque no es una norma certificable como la ISO 27001, su adopción es ampliamente recomendada por su enfoque práctico y su capacidad para integrarse con otros marcos de gestión de riesgos. Muchas organizaciones utilizan ambos marcos de manera complementaria: la ISO

27001 para la gobernanza y el aseguramiento formal, y el NIST CSF para la implementación táctica de controles y la respuesta a incidentes.

Medidas técnicas y organizativas esenciales

La protección efectiva requiere una combinación de controles técnicos y organizativos que varían según el perfil de riesgo de cada entidad, pero que deben incluir:

- **Medidas técnicas:**

- Cifrado de datos en reposo (bases de datos, discos duros) y en tránsito (correos electrónicos, conexiones VPN), para garantizar que, incluso si la información es interceptada o robada, no pueda ser leída sin la clave de descifrado.
- Controles de acceso lógico basados en el principio de mínimo privilegio, autenticación multifactor (MFA) y revisiones periódicas de permisos.
- Copias de seguridad (backups) inmutables y almacenadas fuera de línea o en ubicaciones segregadas, como defensa contra el ransomware.
- Sistemas de prevención y detección de intrusiones (IPS/IDS) y soluciones de seguridad para endpoints (antimalware, EDR) que monitoricen y bloqueen actividades sospechosas en tiempo real.
- Segmentación de redes para limitar el movimiento lateral de un atacante que haya comprometido un segmento inicial.
- Gestión continua de vulnerabilidades mediante escaneos periódicos y la aplicación oportuna de parches de seguridad.

- **Medidas organizativas:**

- **Políticas de seguridad de la información:** Documentos de alto nivel que establecen el compromiso de la dirección, los roles y responsabilidades, y los principios rectores de la seguridad en la organización.

- **Formación y concientización del personal:** Dado que el factor humano sigue siendo el eslabón más débil, los programas de capacitación continua para que los empleados reconozcan intentos de phishing, eviten el uso de contraseñas débiles y reporten incidentes sospechosos son indispensables.
- **Plan de respuesta a incidentes:** Procedimiento documentado que detalla los pasos a seguir ante un ciberataque, desde la contención inicial hasta la recuperación y la comunicación con las partes afectadas y, cuando corresponda, con las autoridades. Este plan debe incluir la preservación de la evidencia digital para posibles acciones legales.
- **Acuerdos de confidencialidad y procedimientos disciplinarios** para empleados y terceros que manejen información sensible.
- **Auditorías internas y externas periódicas** para verificar la efectividad de los controles y el cumplimiento normativo.

Rol del auditor de TI en la intersección entre protección de datos y delitos informáticos

El auditor de Tecnologías de la Información ocupa una posición única y estratégica en la intersección entre la protección de la información y la prevención de delitos informáticos. Su labor no se limita a la verificación de controles, sino que abarca un espectro que va desde la evaluación preventiva hasta la respuesta post-incidente:

- **Identificación de amenazas y evaluación de riesgos de ciberdelincuencia:** El auditor de TI, a través de un análisis de riesgo basado en los activos de información, debe identificar las amenazas de ciberdelincuencia más relevantes para la organización. Esto implica mapear las vulnerabilidades técnicas y humanas que podrían ser explotadas por atacantes para cometer delitos como acceso ilícito, fraude informático o

sabotaje. El resultado de esta evaluación nutre directamente el plan de tratamiento de riesgos y la priorización de los esfuerzos de seguridad.

- **Auditoría de cumplimiento normativo y de eficacia de controles:** Una de las funciones centrales del auditor es verificar el cumplimiento de la Ley 787 (en lo relativo a la protección de datos personales), la Ley 1042 (en cuanto a la existencia de controles que prevengan la comisión de los delitos allí tipificados) y la normativa sectorial aplicable (como la de la SIBOIF para entidades financieras). No obstante, su rol va más allá del mero chequeo de cumplimiento formal: el auditor debe evaluar la **eficacia real** de los controles de seguridad. No basta con que exista una política de copias de seguridad; debe comprobar que las copias se realizan correctamente, que son recuperables en un tiempo razonable y que están protegidas contra el ransomware. La mirada crítica del auditor es clave para detectar la “falsa seguridad” que generan los controles que existen solo en el papel.
- **Papel en la respuesta a incidentes y en la preservación de evidencias digitales:** Cuando un ciberdelito se materializa, el auditor de TI, especialmente si posee formación en informática forense, puede desempeñar un papel crucial. Su conocimiento del entorno tecnológico y de los controles internos le permite colaborar en la identificación del alcance del incidente y en la preservación inicial de las evidencias digitales. Debe seguir los protocolos de cadena de custodia para asegurar que los archivos de registro, las imágenes de discos y cualquier otro rastro digital sean admisibles en un eventual proceso judicial, en sintonía con lo dispuesto en el Código Procesal Penal. Asimismo, está llamado a determinar la causa raíz del incidente: ¿qué vulnerabilidad específica fue explotada? ¿Qué control falló? ¿Fue un error humano, una deficiencia técnica o una combinación de ambos?
- **Emisión de recomendaciones para fortalecer la resiliencia organizacional:** El producto final del trabajo del auditor —el informe de auditoría— debe contener hallazgos claros, evidencias que los respalden y,

sobre todo, recomendaciones viables y priorizadas. Estas recomendaciones deben apuntar a corregir las debilidades encontradas y a fortalecer la postura de seguridad de la organización, elevando su capacidad para resistir (resiliencia) ciberataques futuros. El auditor actúa, en este sentido, como un asesor estratégico que ayuda a la alta dirección a comprender los riesgos tecnológicos y a invertir de manera inteligente en medidas de protección, cerrando así el ciclo de mejora continua que exige tanto la normativa como la realidad de un panorama de amenazas en constante evolución.

Auditoría Informática Forense

La auditoría informática forense representa la convergencia entre la auditoría de sistemas, la investigación criminal y la ciencia forense aplicada al entorno digital. No es simplemente una extensión de la auditoría de TI, sino una disciplina autónoma que exige conocimientos técnicos profundos, dominio del marco jurídico procesal y una metodología rigurosa que garantice la admisibilidad de los hallazgos en un tribunal. En Nicaragua, su relevancia ha crecido de la mano de la Ley N°. 1042, Ley Especial de Ciberdelitos, que demanda investigaciones técnicas sólidas para la persecución de las conductas tipificadas.

Definición, naturaleza y objetivos de la auditoría informática forense

La auditoría informática forense —también denominada informática forense, análisis forense digital o ciberforense— es la disciplina que, mediante la aplicación de metodologías y técnicas especializadas, permite identificar, recolectar, preservar, analizar y presentar evidencia digital de manera que resulte admisible en un proceso judicial o en una investigación corporativa con proyección legal. La evidencia digital comprende cualquier información almacenada o transmitida en formato binario, como archivos de registro, correos electrónicos, metadatos o volcados de memoria, cuyo manejo inadecuado puede comprometer su valor probatorio.

Su naturaleza es dual: **preventiva**, al evaluar vulnerabilidades y controles para anticiparse a incidentes, y **reactiva**, al intervenir una vez que el ilícito se ha materializado para reconstruir los hechos y determinar responsabilidades. Los objetivos que persigue son múltiples y se encadenan lógicamente: detectar incidentes de seguridad que podrían constituir delitos tipificados en la Ley N°. 1042; preservar la evidencia digital conforme a los protocolos de cadena de custodia que exige el ordenamiento procesal nicaragüense; reconstruir la secuencia temporal de los hechos; determinar la autoría y el alcance del daño causado; y, finalmente,

proporcionar el soporte técnico necesario para que el sistema de justicia pueda valorar la prueba y dictar una sentencia con fundamento científico.

Diferencias entre la auditoría de TI tradicional y la auditoría forense

Aunque ambas disciplinas comparten el objeto de examen —los sistemas y datos informáticos—, difieren de manera sustancial en su propósito, metodología y destino de la evidencia.

La **auditoría de TI tradicional** se enfoca en la evaluación del cumplimiento de políticas, normas y controles internos. Su propósito es emitir una opinión sobre la eficacia del sistema de control y formular recomendaciones de mejora. Opera sobre muestras representativas y su planificación es cíclica y predecible. La evidencia que recopila (capturas de pantalla, extractos de configuración) tiene como destino principal el informe de auditoría interna, sin expectativa de ser sometida a contradicción judicial.

La **auditoría informática forense**, en cambio, se activa ante la sospecha fundada de un ilícito. No trabaja sobre muestras, sino que examina la totalidad del soporte digital, bit a bit, para recuperar incluso aquello que se intentó ocultar o destruir. Su propósito no es recomendar mejoras, sino documentar hechos con estándares científicos y legales. La evidencia resultante debe resistir el escrutinio de un juicio oral y público, lo que impone exigencias estrictas: la integridad del dato original debe ser demostrable mediante el cálculo y la verificación del valor hash, y cada manipulación debe quedar registrada en la cadena de custodia. El auditor forense actúa, con frecuencia, en estrecha colaboración con las autoridades encargadas de la persecución penal.

Marco normativo y estándares aplicables a la informática forense en Nicaragua

La práctica de la auditoría informática forense en Nicaragua se desarrolla dentro de un ecosistema normativo compuesto por leyes nacionales, instrumentos internacionales ratificados por el país y estándares técnicos de observancia global.

La **Ley N°. 1042, Ley Especial de Ciberdelitos**, constituye el punto de partida. Su artículo 1 declara que la ley tiene por objeto la prevención, investigación, persecución y sanción de los delitos cometidos por medio de las Tecnologías de la Información y la Comunicación (TIC). Esta norma no solo tipifica las conductas delictivas —acceso ilícito, interceptación de datos, daño informático, entre otras—, sino que implícitamente exige que la investigación de tales delitos se apoye en evidencia digital obtenida y tratada conforme a derecho. La propia ley define conceptos operativos esenciales para el forense, como "datos informáticos", "datos relativos al tráfico" y "dispositivo".

El **Código Procesal Penal de la República de Nicaragua, Ley N°. 406**, aprobado el 13 de noviembre de 2001, proporciona el marco procesal dentro del cual la evidencia forense debe ser incorporada al juicio. Esta norma regula la figura del perito como auxiliar de la administración de justicia, establece los principios de la prueba pericial y, de manera fundamental, sienta las bases de la cadena de custodia. El artículo 210 del Código reconoce la prueba documental como medio probatorio, y el artículo 273 establece disposiciones sobre la custodia de dicha prueba.

Como complemento operativo, el **Manual de Tratamiento de la Evidencia y Cadena de Custodia**, avalado por el Poder Judicial de Nicaragua, estandariza los procedimientos que deben seguir los funcionarios encargados de la recolección, el embalaje, el traslado y el almacenamiento de los elementos materiales de prueba —

incluidos los dispositivos electrónicos—. Este manual es una herramienta de consulta obligada para cualquier perito que aspire a que su evidencia sea admitida sin objeciones en el debate oral.

En el ámbito internacional, Nicaragua ha ratificado instrumentos que facilitan la cooperación en investigaciones de ciberdelincuencia. El **Convenio Iberoamericano de Cooperación sobre Investigación, Aseguramiento y Obtención de Prueba en Materia de Ciberdelincuencia**, aprobado mediante Decreto A.N. N°. 8651 del 25 de febrero de 2020, busca agilizar la asistencia mutua entre los Estados parte para la obtención de pruebas digitales que trascienden las fronteras nacionales. Asimismo, el **Convenio de Budapest sobre la Ciberdelincuencia** (2001) proporciona un referente global para la armonización de los tipos penales y los mecanismos de cooperación internacional.

En cuanto a los estándares técnicos que guían el quehacer forense, destacan:

- **ISO/IEC 27037:2012:** Directrices para la identificación, recopilación, adquisición y preservación de evidencia digital. Esta norma internacional establece los procedimientos tácticos que deben ejecutarse cuando un incidente escala al punto de requerir la recolección de pruebas con valor judicial.
- **ISO/IEC 27041:2015:** Guía para asegurar la idoneidad y adecuación del método de investigación de incidentes de seguridad de la información, garantizando que los procesos utilizados sean los apropiados para el incidente bajo investigación.
- **RFC 3227:** Documento del Internet Engineering Task Force (IETF) que recoge las directrices para la recolección y archivo de evidencia digital. Enfatiza principios como la necesidad de capturar una imagen del sistema tan precisa como sea posible, minimizar los cambios en la información recolectada y recoger los datos según el orden de volatilidad, comenzando por la memoria RAM y los procesos en ejecución.

Metodología y etapas de la auditoría informática forense

La validez de una investigación forense depende, en gran medida, de la aplicación sistemática de una metodología reconocida. Aunque existen diversos modelos (los propuestos por el NIST, por el RFC 3227 o por las normas ISO), todos convergen en un conjunto de fases interdependientes que, ejecutadas correctamente, transforman un dato electrónico en una prueba judicial sólida.

Fase 1 – Identificación y autorización

La investigación forense no puede iniciarse sin una base legal que la sustente. En el ámbito penal, esta base suele ser una orden judicial emanada de la autoridad competente conforme a la Ley N°. 406. En el ámbito corporativo, el mandato puede derivar de las políticas internas de seguridad, de una denuncia ante la Fiscalía o de una decisión de la alta dirección. En esta fase se define el alcance de la investigación, se identifican preliminarmente los sistemas y dispositivos que podrían contener evidencia relevante y se evalúa la escena sin alterarla, documentándola mediante fotografía y notas detalladas.

Fase 2 – Recolección y preservación

Esta es, quizás, la fase más delicada, porque cualquier error en la manipulación inicial de la evidencia puede contaminar todo el proceso posterior y provocar la exclusión de la prueba en el juicio. Implica el levantamiento de los dispositivos en el lugar de los hechos siguiendo estrictos protocolos de cadena de custodia: cada elemento debe ser identificado, etiquetado, embalado en bolsas o contenedores sellados que impidan el acceso no autorizado, y trasladado a un laboratorio forense seguro. Si los equipos están encendidos, el perito debe decidir, conforme a la volatilidad de los datos, si procede realizar un volcado de memoria en caliente antes de apagarlos o si los desconecta de inmediato para prevenir la ejecución de procesos que borren rastros.

Fase 3 – Adquisición forense

La adquisición consiste en obtener una copia bit a bit (imagen forense) de cada soporte de almacenamiento original. Este proceso debe realizarse utilizando un **bloqueador de escritura**, ya sea por hardware o por software, para garantizar que el dispositivo original no sea modificado en lo más mínimo durante la lectura. Una vez obtenida la imagen, se calcula su valor hash utilizando algoritmos como SHA-256. Ese valor —una suerte de huella digital única del contenido— se compara con el hash del original para certificar que la copia es una réplica exacta. A partir de este momento, todo el análisis se realiza sobre la copia forense, preservando el original intacto.

Fase 4 – Análisis forense

Sobre la copia forense, el perito despliega un abanico de técnicas para extraer la información relevante:

- Recuperación de archivos eliminados mediante **file carving**, que busca encabezados y pies de archivo en el espacio no asignado del disco.
- Análisis de la **Master File Table (\$MFT)** en sistemas Windows, que registra cada archivo, su ubicación, fechas de creación, modificación y acceso.
- Examen de los **registros de eventos** del sistema operativo (logs de seguridad, de aplicaciones, de red).
- Construcción de una **línea de tiempo** que correlacione todos los eventos relevantes para reconstruir la secuencia del incidente.
- Análisis de memoria volátil (RAM) para identificar procesos maliciosos, conexiones de red activas o claves de cifrado que residían en ella en el momento de la captura.
- Examen de correos electrónicos, mensajería instantánea y archivos de ofimática, con especial atención a sus metadatos.

El perito debe mantener en todo momento una bitácora de laboratorio donde registre cada paso dado, cada herramienta utilizada y cada hallazgo preliminar.

Fase 5 – Documentación y presentación

El resultado tangible de la auditoría forense es el **informe pericial**, que debe estar redactado con un lenguaje técnicamente preciso pero comprensible para un juez o un fiscal. El informe debe exponer la metodología empleada, las herramientas utilizadas, los hallazgos objetivos y las conclusiones periciales. Es frecuente que el perito deba comparecer en audiencia oral y pública para ratificar su dictamen, explicarlo y responder a las objeciones de las partes. La capacidad de comunicación didáctica del perito es, en esta etapa, tan importante como su competencia técnica.

Herramientas y técnicas de uso común en la práctica forense

La caja de herramientas del auditor forense incluye tanto soluciones de código abierto como plataformas comerciales de alto costo. La elección depende del presupuesto, del tipo de investigación y de la exigencia de que la herramienta esté validada por la comunidad forense, requisito indispensable para que sus resultados resistan el escrutinio judicial.

Entre las **herramientas de adquisición** destacan el **FTK Imager**, de AccessData, una solución gratuita que permite crear imágenes bit a bit de discos duros, memorias USB y volcados de memoria RAM, verificando la integridad mediante hash; y **dd** (y sus variantes como dc3dd o dcfldd), herramientas de línea de comandos presentes de forma nativa en sistemas Linux.

En cuanto a **plataformas de análisis integral**:

- **Autopsy** es una plataforma de código abierto construida sobre The Sleuth Kit. Permite analizar sistemas de archivos Windows, Linux y macOS, y ofrece módulos para la generación de líneas de tiempo, la recuperación de archivos borrados y la extracción de metadatos.

- **EnCase**, desarrollado por Guidance Software (hoy parte de OpenText), es considerado el estándar de oro en el ámbito forense comercial. Ofrece capacidades avanzadas de adquisición, análisis de dispositivos móviles y datos cifrados, y automatización mediante scripts (EnScripts).
- **FTK (Forensic Toolkit)** es otra plataforma comercial que se distingue por su velocidad de procesamiento y la potencia de indexación para búsquedas de texto completo.
- **Volatility** es la herramienta de referencia para el análisis de volcados de memoria RAM, permitiendo identificar procesos ocultos, conexiones de red, claves de registro cargadas en memoria y otros artefactos volátiles que escapan al análisis forense del disco.

Las **técnicas forenses** complementan las herramientas. El *file carving* permite recuperar archivos eliminados incluso cuando los metadatos del sistema de archivos ya no apuntan a ellos. El análisis de la MFT y de los registros de eventos de Windows proporciona una cronología detallada de la actividad del usuario. El análisis de *journaling* en sistemas Linux revela modificaciones que aún no se han consolidado en el sistema de archivos principal. El análisis de tráfico de red capturado (PCAP) puede evidenciar comunicaciones con servidores de comando y control de un atacante.

La cadena de custodia como eje central de la validez probatoria

La cadena de custodia es, sin exageración, la columna vertebral de todo el proceso forense. En el ordenamiento jurídico nicaragüense, su fundamento se encuentra en el Código Procesal Penal (Ley N°. 406), que exige que la prueba que se presenta en el juicio sea exactamente la misma que fue recolectada en la escena del crimen, sin alteración alguna.

La cadena de custodia se define como el procedimiento documentado que garantiza la **identidad** (la prueba es lo que se afirma que es), la **integridad** (no ha sido modificada), la **continuidad** (se sabe en todo momento quién la tuvo y dónde estuvo) y la **seguridad** (estuvo protegida contra accesos no autorizados) de la evidencia. Para ello, se utiliza un formulario o registro cronológico en el que consta cada persona que manipuló la evidencia, el momento exacto en que lo hizo, el propósito de la manipulación y las condiciones de almacenamiento. El Manual de Tratamiento de la Evidencia y Cadena de Custodia del Poder Judicial de Nicaragua estandariza estos procedimientos para todas las instituciones que participan en la investigación criminal.

La **ruptura de la cadena de custodia** —por ejemplo, un dispositivo que permanece sin sellar en un escritorio al que tiene acceso personal no autorizado, o la falta de registro de quién lo manipuló— puede tener consecuencias fatales para el caso: la defensa puede solicitar la exclusión de la prueba, y el tribunal puede declararla nula. El auditor forense debe interiorizar que su trabajo no termina con el hallazgo de un dato incriminatorio, sino que se extiende hasta la demostración irrefutable de que ese dato ha permanecido inalterado desde el momento de su recolección.

El auditor informático forense como perito

La figura del perito es central en el proceso penal nicaragüense. El Código Procesal Penal lo concibe como un auxiliar de la administración de justicia cuyo dictamen constituye un medio de prueba. En el contexto de los ciberdelitos, el perito informático forense es el profesional que traduce la complejidad técnica de la evidencia digital a un lenguaje accesible para el juzgador.

La formación requerida para ejercer esta función es exigente. El perito debe poseer sólidos conocimientos de sistemas operativos, redes, bases de datos, criptografía y

metodología forense. Debe, además, mantenerse actualizado, porque la tecnología y los vectores de ataque cambian a un ritmo vertiginoso. Más allá del conocimiento técnico, el perito debe cultivar cualidades como la **objetividad** (no es un defensor de la parte que lo contrata, sino un servidor de la verdad), la **imparcialidad** (sus hallazgos deben presentarse con independencia de a quién favorezcan), la **ética profesional** (la confidencialidad y la honestidad intelectual son irrenunciables) y la **capacidad de comunicación clara y didáctica** (su dictamen debe ser comprendido por personas que no son expertas en tecnología).

En Nicaragua, la acreditación de peritos puede obtenerse a través de instituciones como la Policía Nacional, que imparte cursos especializados que combinan formación teórica y práctica. A nivel internacional, existen certificaciones que avalan la competencia forense, como CHFI (Computer Hacking Forensic Investigator), EnCE (EnCase Certified Examiner), GCFA (GIAC Certified Forensic Analyst) y CCE (Certified Computer Examiner). Estas certificaciones, aunque no son obligatorias por ley, contribuyen a reforzar la credibilidad del perito ante el tribunal.

Los deberes del perito en el proceso judicial incluyen comparecer ante el juez cuando sea citado, explicar y defender su dictamen, y responder a las preguntas y objeciones que formulen las partes durante el contrainterrogatorio.

El informe pericial forense: estructura y admisibilidad

El informe pericial es el producto final del trabajo del auditor forense y el vehículo a través del cual la evidencia digital ingresa al proceso judicial. Para que sea admisible, debe reunir una serie de requisitos formales y sustanciales.

En cuanto a su **estructura**, un dictamen pericial sólido debe contener, como mínimo:

- **Encabezado:** Identificación del perito (nombre, titulación, número de cédula, certificaciones que lo habilitan), número de caso, juzgado o fiscalía al que se dirige y fecha de emisión.
- **Objeto de la pericia:** Descripción precisa de qué se va a examinar y cuál es el cuestionario planteado por las partes o por el juez. La delimitación del objeto es esencial, porque el perito no puede exceder el mandato que le ha sido conferido.
- **Metodología:** Exposición detallada de los procedimientos empleados, citando las normas técnicas (ISO 27037, RFC 3227) y las herramientas utilizadas, así como la justificación de su elección.
- **Evidencias analizadas:** Relación de los dispositivos, archivos o imágenes forenses examinados, con indicación de sus valores hash para acreditar su integridad.
- **Hallazgos:** Exposición objetiva de los resultados del análisis, sin emitir juicios de valor ni conclusiones anticipadas. Aquí se presentan los archivos recuperados, las líneas de tiempo reconstruidas, los logs que evidencian accesos ilícitos o cualquier otro dato relevante.
- **Conclusiones periciales:** Numeradas y directamente vinculadas al cuestionario inicial. Deben ser claras, concisas y expresar el grado de certeza (o incertidumbre) que la evidencia permite. El perito no emite un veredicto de culpabilidad; eso es competencia exclusiva del juez.
- **Anexos técnicos:** Capturas de pantalla, tablas de datos, referencias a los archivos fuente y cualquier otro respaldo documental que sustente los hallazgos.

La **admisibilidad** del informe está condicionada, como se ha reiterado, a la licitud en la obtención de la evidencia, la integridad documentada mediante hash y cadena de custodia, la solidez de la metodología empleada y la pertinencia de las conclusiones con el objeto del proceso. El juez valorará la prueba pericial conforme

a las reglas de la sana crítica, la lógica y la experiencia, contrastándola con el resto del acervo probatorio.

Tendencias y desafíos actuales de la auditoría informática forense en Nicaragua

La práctica de la auditoría forense en Nicaragua, al igual que en el resto del mundo, enfrenta desafíos derivados de la evolución tecnológica y de la sofisticación de los ciberdelincuentes.

El **cifrado** masivo y las comunicaciones protegidas de extremo a extremo (como las de WhatsApp o Signal) constituyen, quizás, la mayor barrera para el análisis forense. Un dispositivo cifrado que no puede ser desbloqueado se convierte en una caja negra inaccesible para el perito, a menos que se cuente con la cooperación del titular de las claves o con herramientas avanzadas de descifrado, cuyo uso debe ajustarse estrictamente a la legalidad.

La adopción creciente de servicios de **computación en la nube** plantea problemas de jurisdicción y de acceso a la evidencia. Los datos pueden residir en servidores ubicados en múltiples países, lo que obliga a tramitar solicitudes de asistencia judicial internacional a través de mecanismos como el Convenio Iberoamericano ya mencionado. Además, la naturaleza efímera de algunos recursos en la nube (máquinas virtuales que se crean y destruyen dinámicamente, registros que se sobrescriben) dificulta la recolección de una imagen completa y estable del entorno.

Los **dispositivos móviles** se han convertido en repositorios de una cantidad ingente de información personal y corporativa (mensajes, fotografías, correos, ubicaciones GPS, datos de aplicaciones de banca y salud). La diversidad de fabricantes, sistemas operativos y versiones de software, sumada a las medidas de

seguridad cada vez más robustas, exige del perito una especialización continua y el acceso a herramientas forenses móviles actualizadas.

A estos desafíos se suman las **tendencias** que marcarán el futuro de la disciplina: la incorporación de la **inteligencia artificial y el aprendizaje automático** para procesar volúmenes masivos de datos y detectar patrones anómalos que pasarían desapercibidos para un analista humano; la **forensia proactiva**, que integra la capacidad de recolección de evidencia en los sistemas de gestión de seguridad de la información desde antes de que ocurra el incidente (por ejemplo, mediante la activación de registros de auditoría detallados y la preparación de imágenes de referencia de los sistemas críticos); y la necesidad de **laboratorios forenses certificados** a nivel nacional que garanticen la calidad y la uniformidad de los procedimientos.

En el contexto nicaragüense, el fortalecimiento de la capacidad forense es un imperativo. La vigencia de la Ley N°. 1042 y la ratificación de instrumentos internacionales de cooperación crean el marco jurídico propicio, pero su eficacia depende, en última instancia, de la existencia de peritos debidamente formados, de la dotación de laboratorios con herramientas adecuadas y del compromiso de las organizaciones —públicas y privadas— con una cultura de ciberseguridad que haga de la forensia un componente habitual y no un recurso de última hora. Para el auditor de TI, el dominio de los fundamentos de la informática forense ya no es una especialización opcional, sino una competencia esencial para enfrentar un entorno digital donde cada incidente de seguridad es, potencialmente, la escena de un delito.

Bibliografía y Webgrafía

- Mayer Lux, L. y Vera Vega, J. (2024). *Delitos informáticos y cibercriminalidad*. B de F - Euros Editores.
- Rincón Rodríguez, F. (2023). *Delitos informáticos*. Ecoe Ediciones.
- Aboso, G. E. (2023). *Evidencia digital en el proceso penal. La investigación forense en el entorno digital y la validez de las garantías judiciales*. B de F.
- Cardona Pérez, J. D. (2024). *La valoración de la prueba o evidencia digital en los procesos judiciales*. Grupo Editorial Ibáñez.
- Davara Fernández de Marcos, E. y Davara Fernández de Marcos, L. (2022). *Protección de datos: lo que nunca le han contado*. La Ley - Aranzadi.
- Mesa Elneser, A. M. (2020). *Evidencia digital en el derecho colombiano*. Tirant lo Blanch.

- **Adquisición forense:** Fase del proceso forense consistente en obtener una copia bit a bit de un soporte de almacenamiento original, utilizando un bloqueador de escritura y verificando la integridad de la copia mediante el cálculo del valor hash.
- **Auditoría informática forense:** Disciplina que integra la auditoría de TI y la investigación criminal, aplicando metodologías especializadas para identificar, recolectar, preservar, analizar y presentar evidencia digital admisible en un proceso judicial.
- **Autenticidad:** Principio de seguridad que permite verificar que la información proviene de la fuente que dice provenir y que no ha sido suplantada, representando un complemento indispensable de la integridad en el entorno digital.
- **Bloqueador de escritura:** Dispositivo físico o software utilizado en la adquisición forense para impedir cualquier modificación del soporte original durante la lectura, garantizando que la copia bit a bit sea una réplica exacta e inalterada del original.
- **Cadena de custodia:** Procedimiento documentado, de exigencia legal conforme al Código Procesal Penal nicaragüense, que registra cronológicamente cada manipulación de la evidencia, garantizando su identidad, integridad, continuidad y seguridad desde la recolección hasta su presentación en juicio.
- **Confidencialidad:** Principio de la seguridad de la información que garantiza que los datos solo sean accesibles para las personas, entidades o procesos autorizados; se protege mediante cifrado, controles de acceso y acuerdos de confidencialidad.
- **Delito informático:** Conducta ilícita que utiliza las Tecnologías de la Información y la Comunicación como medio o como fin para atentar contra

bienes jurídicos protegidos, como la confidencialidad, integridad y disponibilidad de los datos y sistemas.

- **Disponibilidad:** Principio de la seguridad de la información que asegura que los sistemas y datos estén accesibles y operativos para los usuarios autorizados en el momento en que los requieran; los ataques DDoS y el ransomware constituyen violaciones típicas de este pilar.
- **Evidencia digital:** Cualquier información almacenada o transmitida en formato binario —archivos de registro, correos electrónicos, metadatos— que puede ser utilizada en una investigación o proceso judicial, siempre que se preserve su autenticidad e integridad.
- **Hash:** Valor alfanumérico único, obtenido mediante un algoritmo matemático, que actúa como huella digital de un archivo o disco, permitiendo verificar que la evidencia no ha sido modificada en lo más mínimo durante el proceso forense.
- **Integridad:** Principio de la seguridad de la información que garantiza que los datos se mantengan exactos, completos y sin alteraciones no autorizadas durante todo su ciclo de vida; se protege mediante firmas digitales y funciones hash.
- **Ley N°. 1042:** Ley Especial de Ciberdelitos de Nicaragua, aprobada en octubre de 2020, que tipifica las conductas delictivas cometidas por medio de las TIC y establece el marco para la prevención, investigación, persecución y sanción de los ciberdelitos.
- **Malware:** Software malicioso diseñado para infiltrarse o dañar un sistema informático sin el consentimiento del usuario; incluye virus, troyanos, spyware y ransomware, y su utilización está tipificada en la Ley N°. 1042.
- **No repudio:** Principio de seguridad que impide que el emisor de un mensaje o el autor de una transacción electrónica niegue haberla realizado, garantizado técnicamente mediante mecanismos como la firma electrónica avanzada.

- **Perito informático:** Profesional especializado, titulado y acreditado, que actúa como auxiliar de la administración de justicia, encargado de identificar, preservar, analizar y presentar la evidencia digital en un proceso judicial con objetividad e imparcialidad.
- **Phishing:** Técnica de ingeniería social que, mediante comunicaciones electrónicas fraudulentas, busca engañar al usuario para que revele credenciales de acceso o información confidencial, constituyendo la puerta de entrada a delitos de acceso ilícito y fraude informático.
- **Prueba pericial:** Dictamen escrito u oral emitido por un perito informático, basado en el análisis forense de la evidencia digital, que es admitido y valorado por el juez como medio de prueba conforme a las reglas de la sana crítica.
- **Ransomware:** Tipo de malware que cifra los datos de la víctima y exige un rescate económico a cambio de la clave de descifrado, atentando contra la disponibilidad de la información y constituyendo un delito de extorsión cibernética según la Ley N°. 1042.
- **Trazabilidad:** Capacidad de reconstruir el historial completo de acciones realizadas sobre un dato o sistema, identificando quién hizo qué, cuándo y desde dónde, constituyendo un principio complementario de la seguridad de la información.
- **Volatilidad:** Característica de la evidencia digital que la hace susceptible de perderse o alterarse con facilidad por el simple paso del tiempo, el apagado de un sistema o la ejecución de procesos normales, lo que exige protocolos estrictos de recolección.